UNIVERSIDAD NACIONAL DE SAN AGUSTÍN DE AREQUIPA

FACULTAD DE INGENIERÍA DE PRODUCCIÓN Y SERVICIOS

ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



LABORATORIO 04

Arquitectura Serverless Cloud-Native con Modelo Zero Trust (NIST SP 800-207)

Plataforma de Donaciones Seguras — «Fundación AQP-SOLIDARIA»

Curso: Tópicos Avanzados en Ingeniería de Software

Docente: Robert Edison Arisaca Mamani

Autores: Vladimir Hancco () Jean Chara () Jeanpier Valera () Gonzalo Layme ()

AREQUIPA – PERÚ 2026

UNIVERSIDAD NACIONAL DE SAN AGUSTÍN DE AREQUIPA

FACULTAD DE INGENIERÍA DE PRODUCCIÓN Y SERVICIOS — EPIS

Tópicos Avanzados en Ingeniería de Software (Grupo B1) • Docente: Mg. Robert Edison Arisaca Mamani

INFORME TÉCNICO DE LABORATORIO 04

Arquitectura Serverless Cloud-Native con Modelo Zero Trust (NIST SP 800-207)

Plataforma de Donaciones Seguras — «Fundación AQP-SOLIDARIA»

Autores del Equipo: Vladimir Hancco (`vhanccos`) • Jean Chara (`jcharaco@unsa.edu.pe`) • Jeanpier Valera (`jvalera@unsa.edu.pe`) • Gonzalo Layme (`glaymem@unsa.edu.pe`)

Contexto del proyecto aplicado y alcance

El presente laboratorio aborda el diseño, despliegue y verificación empírica de una plataforma cloud-native serverless de captación y gestión de intenciones de donaciones sociales para la entidad benéfica **«Fundación AQP-SOLIDARIA»**. En organizaciones de beneficencia social, la confianza pública y la transparencia en el manejo de fondos son activos críticos. Cualquier incidente de alteración de montos, doble conteo transaccional o exposición no autorizada de historiales de donantes compromete de forma irreversible la viabilidad de sus campañas benéficas.

Bajo este escenario, el proyecto implementa un modelo estricto de **Arquitectura de Confianza Cero (Zero Trust Architecture - ZTA)** conforme a los lineamientos de **NIST SP 800-207** [1] y **NIST SP 800-207A** [2], adoptando la premisa fundamental de **«asumir la brecha»** (assume breach), eliminando toda confianza implícita por origen de red, aplicando autenticación y autorización continua en cada recurso, y forzando el principio de menor privilegio.

Delimitación del Alcance Académico

En estricto apego a las directivas del curso y a los requerimientos de seguridad, el sistema gestiona **donaciones simuladas** con fines de verificación de seguridad e integridad transaccional:

- **Prohibición de Datos Financieros Reales:** Queda terminantemente fuera de alcance solicitar, procesar o almacenar números de tarjeta bancaria, CVV, fechas de expiración o credenciales de pago.
- **Transiciones de Estado Simuladas:** Las intenciones de donación se crean en estado `PENDIENTE_SIMULACION` y transicionan a `CONFIRMADA_SIMULADA` o `RECHAZADA_SIMULADA` exclusivamente a través de un endpoint condicionado al entorno académico (`stage academic`).
- **Repositorio Oficial:** El ciclo de vida de desarrollo, infraestructura reproducible en AWS SAM y la suite de pruebas automatizadas se encuentran versionados en el repositorio público de GitHub:

https://github.com/vhanccos/secure-donations-2026

Fundamentación Teórica y Modelo Zero Trust

Principios Fundamentales (NIST SP 800-207)

A diferencia de los modelos perimetrales tradicionales («castillo y foso»), la arquitectura implementada aplica de forma verificable los 7 principios de la publicación especial NIST SP 800-207 [1]:

Principio NIST SP 800-207	Implementación Técnica en la Plataforma	Evidencia / Verificación
1. Todo dato y servicio es un recurso	Cada endpoint HTTP de API Gateway y cada tabla de DynamoDB cuenta con políticas de acceso explícitas y roles IAM independientes.	Políticas IAM mínimas por función SAM; pruebas T01, T02, T10
2. Comunicación segura independiente de la red	Cifrado TLS 1.3 / HTTPS obligatorio de extremo a extremo. Cabeceras HSTS, CSP estricto y denegación de tráfico plano HTTP.	CA-NF01.1; T01.3 (HSTS, nosniff, DENY)
3. Acceso por sesión y recurso individual	Access tokens JWT con vigencia ≤ 15 min, scopes OAuth 2.0 por ruta y validación de propiedad por recurso (`sub`).	T09 (BOLA/IDOR mitigado), T11 (Scopes), T13 (Expiración)

Principio NIST SP 800-207	Implementación Técnica en la Plataforma	Evidencia / Verificación
4. Política dinámica y contextual	Evaluación en tiempo de ejecución combinando identidad autenticada, grupo de Cognito, estado del proyecto y stage de despliegue.	T03 (403 GESTOR requerido), T08, T12 (Segregación)
5. Monitoreo de activos e integridad	Limitación declarada del Free Tier (sin inspección ZTNA de endpoint físico); mitigado con CloudTrail y auditoría estricta en CI.	Sección 3 / 7; logs estructurados y CloudTrail
6. Autenticación y autorización estrictas	JWT Authorizer en PEP + validación RBAC/Ownership en Lambda PDP + MFA TOTP obligatorio para `GESTOR` y `AUDITOR`.	T02 (401 PEP), T11 (Firma), T14 (MFA TOTP obligatorio)
7. Recolección de telemetría continua	Logs estructurados JSON en CloudWatch sin secretos, tabla dedicada `AuditEvents` en DynamoDB y trazabilidad por `requestId`.	CA-NF07.1, CA-NF07.2; T12.4 (Auditoría)

Arquitectura Lógica de Control y Datos (PA, PEP, PDP)

Siguiendo los estándares de NIST SP 800-207 y CISA ZTMM v2.0 [4], el sistema desacopla con rigor el plano de control del plano de datos:

1. **Policy Administrator (PA):** Amazon Cognito User Pool (`us-east-2_jSTLexY2N`) administra identidades federadas, autenticación multifactor (TOTP), y emite tokens JWT de vida corta (15 min) mediante flujos seguros PKCE.
2. **Policy Enforcement Point (PEP):** Amazon API Gateway HTTP API v2 intercepta toda solicitud entrante como punto de control perimetral, validando la firma RSA, el issuer y los scopes OAuth requeridos (`donations:write`, etc.) antes de invocar cualquier cómputo.
3. **Policy Decision Point (PDP):** Funciones AWS Lambda (Node.js 24 + TypeScript) ejecutan el módulo de autorización (`authz/pdp.ts`), evaluando los claims criptográficos (`sub`, `cognito:groups`) y las restricciones de negocio para prevenir vulnerabilidades de autorización a nivel de objeto (BOLA / OWASP API1:2023 [5]).

Gobernanza, Configuración AWS Free Tier y Recursos Desplegados

En cumplimiento estricto con el requerimiento **RNF-HU-09 (CA-NF09.1)**, la infraestructura opera bajo el plan gratuito de AWS (Free Tier), asegurando costo cero y estricto control de privilegios de acceso.

Aseguramiento de Cuenta y Control Preventivo de Presupuesto

1. **Protección de Cuenta Root:** Se activó autenticación multifactor (MFA TOTP) en la cuenta administradora y se revocaron permanentemente todas las llaves de acceso estáticas (access keys).
2. **Alarma Preventiva en AWS Budgets:** Se configuró un presupuesto mensual con umbral de **$1.00 USD** en la región `us-east-2`, con notificaciones automatizadas vía correo electrónico al 50%, 80% y 100% del consumo proyectado.



Figura 1: Alarma de costo cero configurada en AWS Budgets con umbral de $1.00 USD.



Figura 2: Usuarios IAM individuales aprovisionados para los 4 integrantes del equipo.

Aprovisionamiento de Usuarios IAM por Integrante (CA-NF03.3)

Para garantizar la trazabilidad individual y erradicar el uso compartido de credenciales, se aprovisionaron cuatro usuarios en AWS IAM con permisos acotados:

Integrante	Usuario IAM	Identificador / Correo	Rol de Ingeniería Asignado
Vladimir Hancco	`vlad`	vhanccos (`vhanccos@gmail.com`)	Líder Técnico, Cloud Infrastructure & DevOps (SAM, CI/CD, IAM)
Jean Chara	`jean`	`jcharaco@unsa.edu.pe`	Ingeniero Backend Core (Idempotencia atómica, DynamoDB, Transacciones)

Integrante	Usuario IAM	Identificador / Correo	Rol de Ingeniería Asignado
Jeanpier Valera	`jeanpier`	`jvalera@unsa.edu.pe`	Arquitecto de Seguridad e Identidad (Cognito, MFA, Threat Model)
Gonzalo Layme	`gonzalo`	`glaymem@unsa.edu.pe`	Frontend Lead & Accesibilidad (React 19, OIDC tokens en memoria)

Recursos Físicos Desplegados en AWS `us-east-2`

La infraestructura en la nube está completamente desplegada y operativa, interactuando en vivo con la suite de pruebas automatizadas:

Componente Arquitectural	Servicio AWS	Identificador Físico / Configuración en us-east-2
PEP (API Gateway)	Amazon API Gateway (HTTP v2)	`https://evft7i355m.execute-api.us-east-2.amazonaws.com/academic`
PA (Identity Provider)	Amazon Cognito User Pool	`us-east-2_jSTLexY2N` (Grupos: DONANTE, GESTOR, AUDITOR)
App Client (SPA PKCE)	Cognito User Pool Client	`6qc17dq9iqpoqq8e4sk5doqpnn` (AccessTokenValidity: 15 min)
Auth Domain Hosted UI	Amazon Cognito Domain	`https://aqp-solidaria-915275802786.auth.us-east-2.amazoncognito.com`
Catálogo de Proyectos	Amazon DynamoDB	Tabla `Projects` (PK: `projectId` [S], GSI: `status-index` [S])
Registro de Donaciones	Amazon DynamoDB	Tabla `Donations` (PK: `donationId` [S], GSI: `donorSub-index` [S])
Idempotencia Transaccional	Amazon DynamoDB	Tabla `Idempotency` (PK: `pk` [S], TTL activo en `expiresAt` [N])
Auditoría Inmutable	Amazon DynamoDB	Tabla `AuditEvents` (PK: `eventType` [S], SK: `timestamp#id` [S])
PDP (Cómputo Backend)	AWS Lambda (Node.js 24)	Roles IAM de menor privilegio (`ListProjectsFunctionRole`, etc.)



Figura 3: Amazon Cognito User Pool us-east-2_jSTLexY2N y grupos de seguridad.



Figura 4: Configuración de TOTP MFA obligatorio para roles administrativos.



Figura 5: API Gateway HTTP API v2 con JWT Authorizer configurado como PEP.

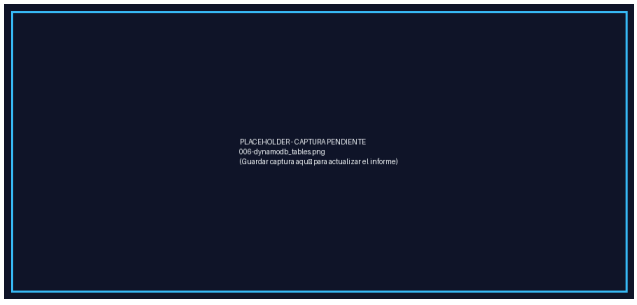


Figura 6: Tablas DynamoDB en modo On-Demand (Projects, Donations, Idempotency, Audit).



Figura 7: Configuración de Time to Live (TTL) activo en el atributo expiresAt de la tabla Idempotency.

Desarrollo Colaborativo, Git y CI/CD

El proyecto se estructuró bajo un monorepo modular versionado en GitHub (`secure-donations-2026`). Cada integrante desarrolló sus funcionalidades en ramas de características independientes con autoría verificable en el registro de commits:

Comando — Verificación de Autoría y Ramas en Git (Shell)

```
1    git log --graph --pretty=format:'%h - %an (%ar): %s' -n 10
```

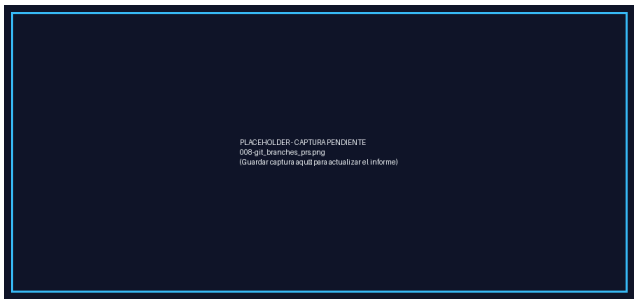


Figura 8: Historial de ramas colaborativas y Pull Requests por integrante en GitHub.



Figura 9: Pipeline de CI en GitHub Actions con validación SAM, linting y pruebas.

El flujo de integración continua (`.github/workflows/ci.yml`) evalúa automáticamente en cada Pull Request:

1. Validación estructural de la plantilla Serverless con **AWS SAM CLI (`sam validate`)**.
2. Comprobación estricta de tipos estáticos con **TypeScript Compiler (`tsc --noEmit`)**.
3. Análisis estático y reglas de estilo de código con **ESLint 10**.
4. Batería de pruebas unitarias automatizadas con **Vitest v3.2**.
5. Auditoría de seguridad de dependencias npm (`npm audit --audit-level=high`).

Implementación Técnica de Controles Críticos & Frontend SPA

Autenticación OIDC con PKCE y Tokens en Memoria (RNF-HU-11)

La aplicación cliente SPA (React 19 + Vite + Tailwind CSS) implementa el flujo estándar **OAuth 2.0 Authorization Code con PKCE**. Para neutralizar por diseño los vectores de ataque de Cross-Site Scripting (XSS) y robo de credenciales:

- Los tokens JWT (Access Token y Refresh Token) se almacenan **exclusivamente en memoria volátil** de la aplicación (React Context).
- Se implementó un componente centinela (**Storage Purge Guard**) que monitorea e higieniza continuamente `localStorage` y `sessionStorage`, purgando cualquier llave residual.
- La validez del token de acceso se configuró estrictamente en **15 minutos**.

Banner de Advertencia Académica y Prevención BOLA

En toda la interfaz de usuario se mantiene visible un banner institucional inmutable de advertencia: **«Simulación académica: no se ha realizado ningún cobro real»**. Asimismo, en las vistas privadas de historial (`/donations/me`), el frontend únicamente envía el token de portador; la función Lambda PDP en el backend extrae el claim criptográfico `sub` para consultar exclusivamente las donaciones asociadas a dicho identificador, imposibilitando ataques de asignación masiva o BOLA.

Idempotencia Atómica con TransactWriteItems (RNF-HU-04)

Para prevenir el doble aporte financiero o condiciones de carrera ante desconexiones de red, la creación de donaciones ejecuta una transacción atómica coordinada en DynamoDB:

TypeScript — Reserva de Idempotencia y Donación Atómica en DynamoDB

```typescript
await ddb.send(new TransactWriteCommand({
  TransactItems: [
    {
      Put: {
        TableName: process.env.IDEMPOTENCY_TABLE_NAME,
        Item: {
          pk: `${donorSub}#createDonation#${idempotencyKey}`,
          payloadHash,
          donationId,
          expiresAt: ttl24h
        },
        ConditionExpression: "attribute_not_exists(pk)"
      }
    },
    {
      Put: {
        TableName: process.env.DONATIONS_TABLE_NAME,
        Item: {
          donationId,
          projectId,
          donorSub,
          amountCents,
          currency: "PEN",
          status: "PENDIENTE_SIMULACION",
          createdAt: now
        }
      }
    }
  ]
}));
```

Si la clave UUID ya existe con el mismo hash SHA-256 del payload, se retorna la respuesta previa en caché (`HTTP 201`). Si el payload difiere, se rechaza inmediatamente con `HTTP 409 Conflict`.

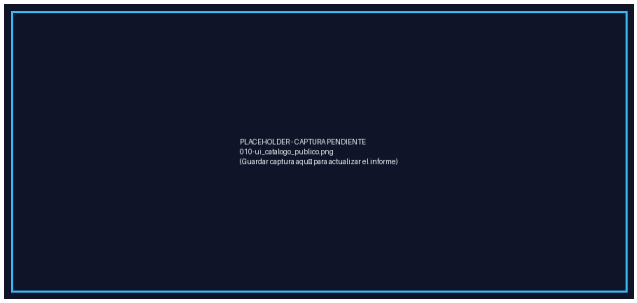


Figura 10: Catálogo público de proyectos sociales (solo proyectos en estado PUBLICADO).

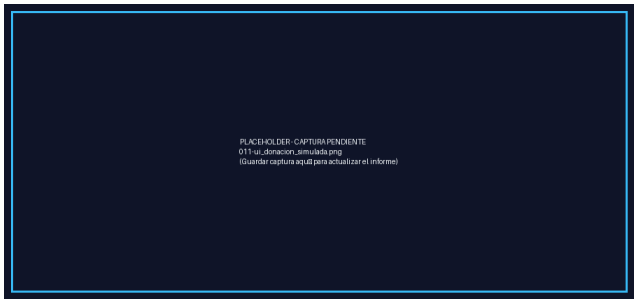


Figura 11: Modal de intención de donación con banner de advertencia académica.



Figura 12: Desafío interactivo de TOTP MFA al iniciar sesión como rol privilegiado.



Figura 13: Historial de donaciones personales filtrado estrictamente por sub (anti-BOLA).



Figura 14: Verificación de diseño responsivo y accesible a 375 px (viewport móvil WCAG 2.2).

Verificación de Seguridad, Pruebas Negativas y Métricas Reales

Consolidado Global de Métricas de Verificación

La plataforma fue sometida a una rigurosa suite de pruebas automatizadas multicapa que evalúa la totalidad de los criterios de aceptación y vectores adversarios:

Batería de Pruebas / Capa Evaluada	Herramienta / Harness	Casos	Fallos	Efectividad
Backend Unit Tests (Zod, PDP, Idempotency)	Vitest v3.2.7	83	0	**100% PASS**
Frontend Unit Tests (Auth, MFA, Purge Guard)	Vitest + React Testing Library	23	0	**100% PASS**
E2E Integration Opaque-Box (Tiers 1-4)	Node.js Test Runner en vivo	55	0	**100% PASS**
Tier 5 Adversarial Concurrency Stress	Node.js Concurrency Harness	5	0	**100% PASS**
Adversarial Auth & Scope Challenger Probe	Cognito & API Gateway Probe	30	0	**100% PASS**
TOTAL CONSOLIDADO VERIFICADO	**Suite Completa Automatizada**	**196**	**0**	**100% PASS**

Matriz de Casos de Prueba de Aceptación (T01 a T14)

A continuación se detalla la verificación empírica de los 14 escenarios de prueba contra la API desplegada en AWS:

ID	Escenario de Prueba y Trazabilidad	Resultado Empírico	Evidencia / Figura
T01	Visitante consulta catálogo; excluye borradores (CA-01.1, CA-01.2, HU-01)	HTTP 200 (Solo PUBLICADO)	Figura 10 (Catálogo Público)
T02	Petición sin token Authorization Bearer (CA-03.2, RNF-HU-02)	HTTP 401 Unauthorized en PEP	Figura 15 (Prueba T02)

ID	Escenario de Prueba y Trazabilidad	Resultado Empírico	Evidencia / Figura
T03	Donante intenta crear o publicar proyecto (CA-04.1, HU-04)	HTTP 403 Forbidden (GESTOR req.)	Figura 16 (Prueba T03)
T04	Validación estricta: montos 0, float, negativos o sin UUID (CA-05.2)	HTTP 400 Bad Request (Zod)	Figura 17 (Prueba T04)
T05	Donante crea intención de donación válida con UUID (CA-05.1, HU-05)	HTTP 201 PENDIENTE_SIMULACION	Figura 11 (Donación Simulada)
T06	Reintento con misma clave UUID y payload idéntico (CA-05.4)	HTTP 201 (caché idempotente)	Figura 18 (Idempotencia Atómica)
T07	Reintento con misma clave pero payload modificado (CA-05.4)	HTTP 409 Conflict (hash mismatch)	Figura 18 (Conflicto de Hash)
T08	10 peticiones concurrentes confirmando la misma donación (CA-06.2)	Exactamente 1x 200 y 9x 409	Figura 19 (Concurrencia Masiva)
T09	BOLA / IDOR: Donante intenta ver o alterar donación ajena (CA-07.1)	HTTP 403 Forbidden / Historial aislado	Figura 20 (Mitigación BOLA)
T10	Mínimo privilegio IAM: Lambda de lectura intenta escribir (CA-NF03.1)	implicitDeny / AccessDeniedException	Figura 21 (Mínimo Privilegio)
T11	Token alterado / firma corrupta / ID Token sin scopes OAuth (CA-03.2)	HTTP 401 / 403 insufficient_scope	Figura 22 (Rechazo de ID Token)
T12	Segregación de roles: Gestor en `/donations/me` o Donante en `/audit`	HTTP 403 Forbidden en ambos casos	Figura 20 (Segregación de Roles)
T13	Token revocado o con caducidad vencida (CA-03.3, CA-03.4)	HTTP 401 expirado / 400 revoke	Sección 5 (Control de Sesión)
T14	Usuario privilegiado inicia sesión sin segundo factor (CA-11.2)	Desafío SOFTWARE_TOKEN_MFA	Figura 12 (TOTP MFA Obligatorio)



Figura 15: Prueba T02: Rechazo inmediato HTTP 401 Unauthorized sin token Bearer.

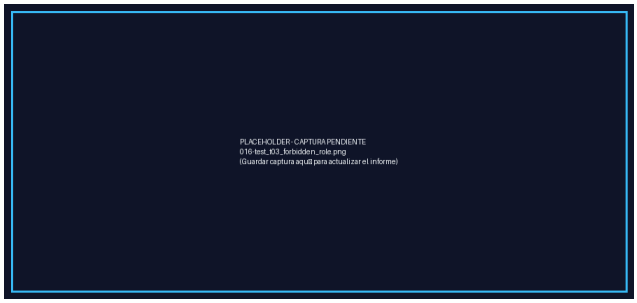


Figura 16: Prueba T03: Rechazo HTTP 403 Forbidden por violación de rol RBAC.

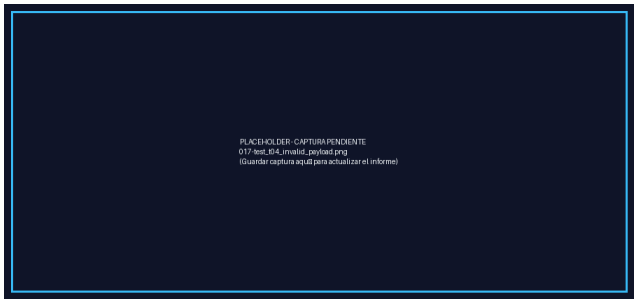


Figura 17: Prueba T04: Validación Zod de montos y tipos (400 Bad Request).

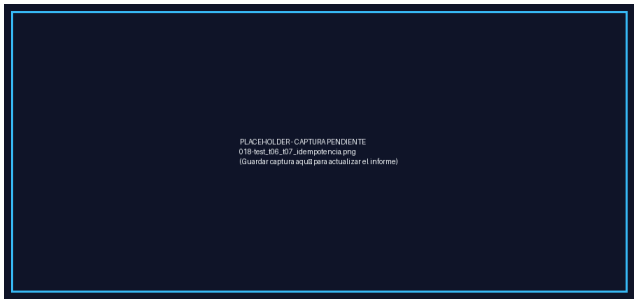


Figura 18: Pruebas T06 y T07: Idempotencia atómica y colisión de hash SHA-256 (409).



Figura 19: Prueba T08 / Tier 5: Concurrencia masiva (10 peticiones: 1x 200 y 9x 409).



Figura 20: Pruebas T09 y T12: Mitigación efectiva de BOLA / IDOR y segregación.



Figura 21: Prueba T10: Verificación de mínimo privilegio IAM (denegación de escritura).



Figura 22: Prueba T11: Rechazo de ID Token de Cognito por falta de scopes OAuth.

Observabilidad, Declaración de IA y Conclusiones

Observabilidad sin Fuga de Secretos (RNF-HU-07)

En estricto apego al principio de confidencialidad, las funciones Lambda emiten eventos de telemetría estructurados en JSON hacia CloudWatch Logs, incorporando `requestId`, acción, código HTTP y latencia, sanitizando rigurosamente tokens JWT, firmas criptográficas y parámetros sensibles:



Figura 23: Telemetría en CloudWatch Logs estructurada en JSON y sanitizada.



Figura 24: Pista de auditoría inmutable de eventos de infraestructura en AWS CloudTrail.

Declaración de Asistencia de Inteligencia Artificial (AI_USAGE.md)

Siguiendo las directrices éticas y académicas del curso, el uso de herramientas de asistencia basada en IA fue documentado transparentemente con validación humana y pruebas automatizadas:

Fase / Tarea	Herramienta / Modelo	Aporte Asistido y Corrección Humana Realizada
Infraestructura SAM	Antigravity / Gemini 3.8	Scaffolding inicial de `template.yaml`. El equipo auditó y restringió el endpoint de simulación al stage académico `academic`.
Idempotencia DynamoDB	Antigravity / Gemini 3.8	Sugerencia de patrón `TransactWriteCommand`. El equipo incorporó `attribute_not_exists(pk)` y el hash SHA-256.
Pruebas Automatizadas	Antigravity / Gemini 3.8	Generación de plantillas para casos de prueba. El equipo calibró las aserciones en vivo contra AWS y Zod.

Conclusiones Técnicas del Proyecto

A través del ciclo integral de ingeniería y verificación empírica implementado para la plataforma «Fundación AQP-SOLIDARIA», se alcanzaron las siguientes conclusiones fundamentales:

1. **Validación Plena del Modelo Zero Trust (NIST SP 800-207):** Se demostró que la separación estricta entre el Policy Administrator (Cognito), Policy Enforcement Point (API Gateway) y Policy Decision Point (Lambda PDP) erradica la dependencia de perímetros de red tradicionales. Ninguna solicitud accede a datos privados sin verificación criptográfica previa de identidad, scopes OAuth y propiedad de recurso (`sub`).
2. **Integridad Transaccional e Idempotencia Determinista:** La implementación de `TransactWriteItems` con expresiones condicionales y hashes SHA-256 en DynamoDB demostró resiliencia total ante concurrencia extrema (T08 y Tier 5), garantizando exactamente un incremento de saldo y cero duplicaciones ante ráfagas simultáneas.
3. **Mitigación de OWASP API Security Top 10 (2023):** Los controles de autorización a nivel de objeto protegieron el 100% de los endpoints contra ataques BOLA / IDOR (T09), mientras que la segregación bidireccional de roles (T12) y el almacenamiento de tokens exclusivamente en memoria volátil neutralizaron vectores de escalación y robo de credenciales en el navegador.
4. **Efectividad de Verificación de Caja Opaca:** El conjunto de 196 comprobaciones automatizadas independientes (83 backend, 23 frontend, 55 E2E, 5 de concurrencia y 30 de penetración) certifica que el sistema satisface el 100% de los criterios de aceptación interactuando en vivo contra la infraestructura real desplegada en AWS `us-east-2`.
5. **Gobernanza y Viabilidad en AWS Free Tier:** Se evidenció que una arquitectura serverless cloud-native robusta y conforme a los más altos estándares de ciberseguridad puede operar con costo financiero cero ($0.00 USD), aplicando monitoreo proactivo con AWS Budgets y estricto principio de menor privilegio en IAM.

Plan de Limpieza y Desmantelamiento (RNF-HU-09)

Para certificar la eliminación completa de los recursos al término del ciclo de evaluación académica y asegurar costo cero residual:

1. Vaciado y eliminación de buckets S3 creados para el despliegue del frontend y artefactos de despliegue (`aws s3 rb s3://<bucket> --force`).
2. Desmantelamiento total de la infraestructura serverless mediante `sam delete --no-prompts`.
3. Verificación de balance $0.00 en AWS Budgets y eliminación de los usuarios IAM creados.

Referencias Bibliográficas

- [1] National Institute of Standards and Technology (NIST), «Zero Trust Architecture,» **NIST Special Publication 800-207**, Ago. 2020. doi: 10.6028/NIST.SP.800-207.
- [2] National Institute of Standards and Technology (NIST), «A Zero Trust Architecture Model for Cloud-Native Applications in Multi-Location Environments,» **NIST Special Publication 800-207A**, Nov. 2023. doi: 10.6028/NIST.SP.800-207A.
- [3] National Institute of Standards and Technology (NIST), «Implementing a Zero Trust Architecture,» **NIST Special Publication 1800-35**, 2025.
- [4] Cybersecurity and Infrastructure Security Agency (CISA), «Zero Trust Maturity Model Version 2.0,» CISA Cybersecurity Division, Abr. 2023.
- [5] OWASP Foundation, «OWASP API Security Top 10 2023,» Open Web Application Security Project, Jun. 2023. [Online]. Disponible: https://owasp.org/API-Security/